



Universidad Tecnológica de Querétaro

INGENIERÍA EN DESARROLLO Y GESTIÓN DE SOFTWARE

Materia:

Seguridad en el Desarrollo de Aplicaciones

Maestro:

Gerardo Ramírez Villarreal

Grupo:

IDGS17

Nombre Alumno:

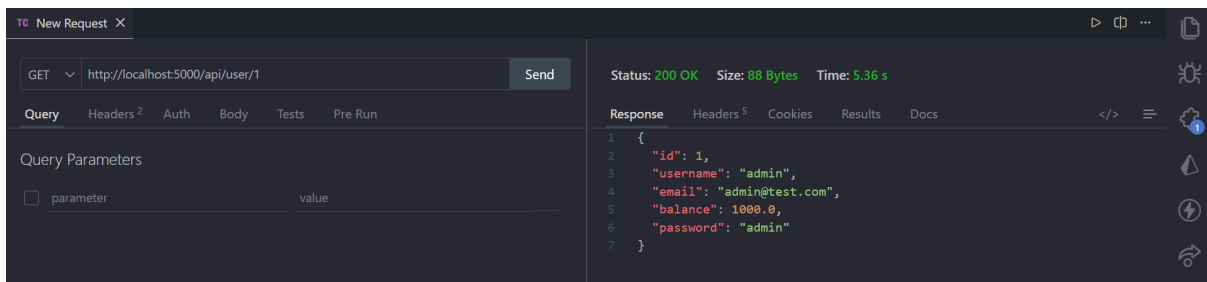
Luis Eduardo Rios Cervantes

Trabajo:

Insecure Direct Object References IDOR

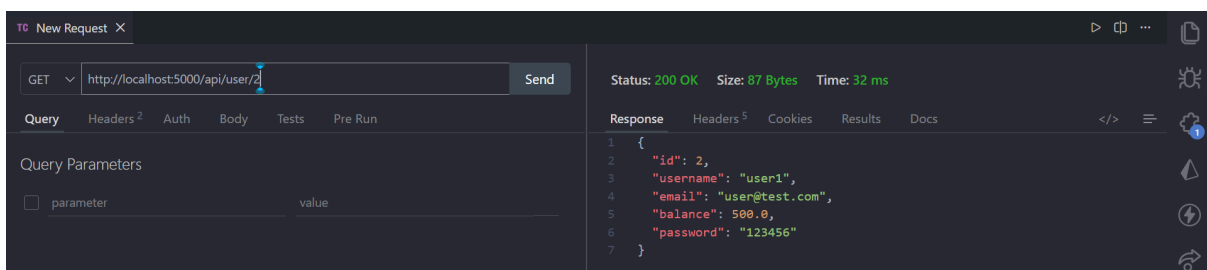
Querétaro, Qro. 04 de Junio de 2026

Registrar qué campos se devuelven.



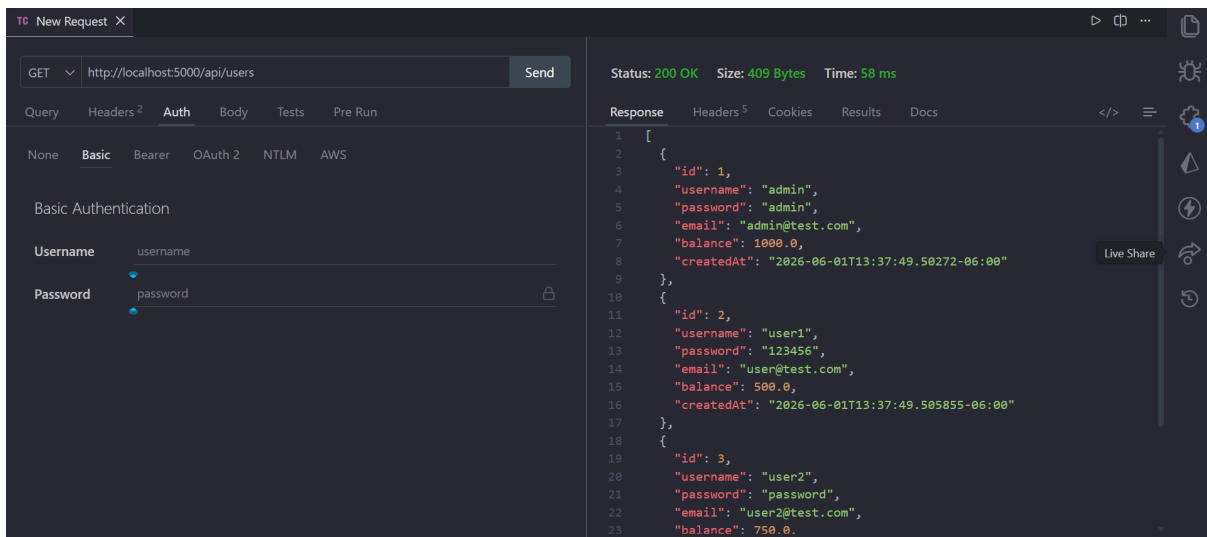
Id, username, email, balance y password.

Identificar si se muestra información sensible.



La petición devuelve el id del usuario, su contraseña y su balance, los cuales son información sensible y confidencial.

Analizar si el endpoint válida identidad del usuario.



Los endpoint no validan la identidad del usuario para mostrar los datos de la petición.

Explicar por qué el uso de ids consecutivos facilita la enumeración.

El uso de identificadores (IDs) consecutivos o autoincrementales facilita la enumeración porque permite a cualquier usuario o programa predecir el siguiente valor en la secuencia.

matemática (ej. $\setminus(1, 2, 3 \dots x + 1 \setminus)$). Esta previsibilidad conlleva serios riesgos de seguridad y privacidad, conocidos como ataques de IDOR (Insecure Direct Object Reference).